Scalable Web Application on AWS

EC2, Application Load Balancer and Auto Scaling

Architecture Design Report

Project	Scalable Web Application with ALB and Auto Scaling (EC2-based)
AWS Region	us-east-1 (N. Virginia)
Date	21 October 2026
Document type	Architecture design documentation
Status	Design only. The architecture has not been deployed or load-tested for this submission.

1. Summary

This report covers the design of a web application on AWS that keeps working if one Availability Zone goes down and can grow when traffic goes up. The web servers and the database sit in private subnets spread over two Availability Zones. Users reach the application through CloudFront and an Application Load Balancer, and AWS WAF filters the requests at the load balancer.

The web servers run in an Auto Scaling group. The data is kept in an RDS for MySQL database that has a standby copy in the second zone. There is no bastion host and no SSH access. Admins connect through Session Manager, and CloudWatch alarms send an email through SNS when something looks wrong.

This is a design document only. Nothing in it has been deployed or tested in a real AWS account, and the known weak points are listed in section 12.

2. Business Problem and Objectives

Running a web application on a single server is risky. If that server fails, the site is down. It cannot handle a sudden rush of visitors, the server and database are often exposed to the internet, and nobody can easily see what is happening inside. The design goes after these problems one by one.

Objective	**How the design addresses it**
Stay available if an Availability Zone fails	Resources in two AZs; ALB across both; RDS Multi-AZ; one NAT Gateway per AZ
Scale with demand	Auto Scaling group (minimum 2, desired 2, maximum 6) with target tracking policies
Reduce latency for static content	CloudFront caches /static/*
Protect the application	AWS WAF, security groups, network ACLs, private subnets, no public IPs on instances or database
Remove bastion hosts	Session Manager for instance access
Notice problems early	Five CloudWatch alarms that email an SNS topic, plus a dashboard

3. Scope and Assumptions

This is an architecture design and documentation deliverable. Please keep these points in mind while reading it.

- The design is for a single Region, us-east-1.
- Nothing has been deployed, load-tested, or checked in a live AWS account for this submission, so the report makes no claims about real-world results.
- There are no price figures, because current AWS prices could not be verified. Section 11 describes the cost drivers in words instead.
- Route 53 is drawn as optional and is not turned on in the baseline.
- The Auto Scaling group is assumed to use ELB health checks, so an instance that fails the load balancer check gets replaced. The diagram does not say which health check type is used.

4. Solution Architecture Diagram

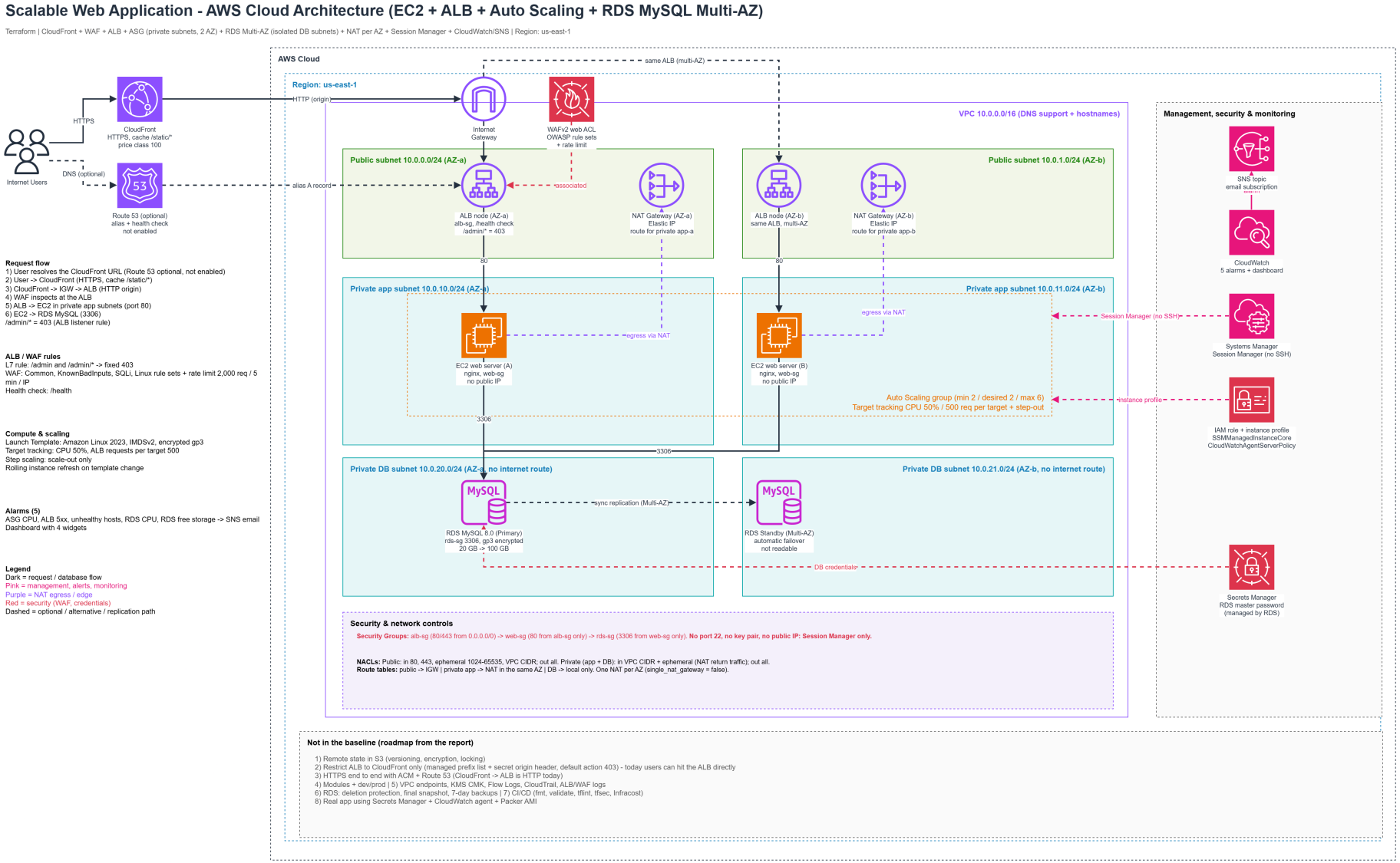


Figure 1. Solution architecture of the scalable web application.

5. Architecture Description

The design splits into five layers.

Layer	Components	Role
Edge	Amazon CloudFront; optional Route 53 alias	HTTPS for viewers; caches /static/*; optional DNS alias to the ALB with a health check
Entry	Internet Gateway; Application Load Balancer; AWS WAF	Public entry point, Layer 7 routing and request filtering
Application	EC2 instances (nginx) in an Auto Scaling group	Serve the web application from the private app subnets
Data	Amazon RDS for MySQL 8.0, Multi-AZ	Store data in private DB subnets that have no internet route
Operations	Systems Manager, IAM, CloudWatch, SNS, Secrets Manager	Access, permissions, monitoring, email alerts and credential storage

5.1 AWS services and what each one does

Service	Responsibility in this design
Amazon VPC	Network 10.0.0.0/16 with public, private app and private DB subnets in two AZs; route tables, security groups and network ACLs
Internet Gateway	Internet entry and exit for the public subnets
NAT Gateway (one per AZ)	Outbound-only internet access for the private app instances, for example OS updates and Systems Manager connectivity
Amazon CloudFront	HTTPS for viewers; caches /static/*; price class 100; uses the ALB as an HTTP origin
AWS WAF (WAFv2)	Web ACL on the ALB with the managed Common, Known Bad Inputs, SQL injection and Linux rule sets, plus a rate limit of 2,000 requests per 5 minutes per IP
Application Load Balancer	Layer 7 balancing across both AZs; health check on /health; fixed 403 response for /admin and /admin/*
Amazon EC2	nginx web servers on Amazon Linux 2023; IMDSv2 required; encrypted gp3 volumes; no public IP
EC2 Auto Scaling	Launch template; minimum 2, desired 2, maximum 6; target tracking policies; scale-out step policy; rolling instance refresh
Amazon RDS for MySQL 8.0	Multi-AZ database with automatic failover; encrypted gp3 storage, 20 GB that can grow to 100 GB
AWS Secrets Manager	Holds the RDS master password, which RDS manages
AWS Systems Manager	Session Manager for shell access without SSH
AWS IAM	Instance role and profile with AmazonSSMManagedInstanceCore and CloudWatchAgentServerPolicy
Amazon CloudWatch	Five alarms and one dashboard with four widgets
Amazon SNS	Email subscription that receives the alarm notifications
Amazon Route 53 (optional)	Alias A record to the ALB with a health check; not turned on in the baseline

6. Network Design

The VPC uses the CIDR block 10.0.0.0/16 with DNS support and DNS hostnames turned on. Every tier has one subnet in each Availability Zone.

Tier	AZ-a	AZ-b	Contents	Default route
Public	10.0.0.0/24	10.0.1.0/24	ALB nodes; NAT Gateways with Elastic IPs	Internet Gateway
Private app	10.0.10.0/24	10.0.11.0/24	EC2 web servers	NAT Gateway in the same AZ
Private DB	10.0.20.0/24	10.0.21.0/24	RDS primary and standby	None (local traffic only)

Network ACLs

- Public subnets: inbound 80, 443, ephemeral ports 1024-65535 and VPC CIDR traffic. All outbound traffic is allowed.
- Private subnets (app and DB): inbound from the VPC CIDR plus ephemeral ports, which the NAT return traffic needs. All outbound traffic is allowed.

Each AZ has its own NAT Gateway, so outbound access in one AZ does not depend on the other.

7. Application Request Flow

1. The user looks up the CloudFront address. Route 53 is optional and is not turned on in the baseline.
2. The user connects to CloudFront over HTTPS. Requests for /static/* can be answered from the cache.
3. For cache misses and dynamic paths, CloudFront sends the request over HTTP to the Application Load Balancer through the Internet Gateway.
4. AWS WAF checks the request at the ALB. Requests to /admin and /admin/* get a fixed 403 response from an ALB listener rule.
5. The ALB passes allowed requests on port 80 to the EC2 instances in the private app subnets.
6. The application on EC2 talks to RDS MySQL on port 3306 in the private DB subnets.

When the instances need the internet, for example for package updates, their traffic goes out through the NAT Gateway in the same AZ.

8. Security Design

Security is built in layers, so if one control fails the next one still protects the system.

Security group	Inbound	Source
alb-sg	TCP 80 and 443	0.0.0.0/0
web-sg	TCP 80	alb-sg only
rds-sg	TCP 3306	web-sg only

Layer	Controls
Edge	CloudFront with HTTPS for viewers; WAF managed rule sets and rate limiting at the ALB
Network	Three-tier subnets; no public IPs on instances or database; DB subnets with no internet route; network ACLs as a second layer

Layer	Controls
Access	Session Manager only: no port 22, no key pair, no bastion host
Instance	IMDSv2 required; encrypted gp3 volumes; AWS managed policies on the instance role
Data	Encrypted RDS storage; master password managed through Secrets Manager
Application	/admin and /admin/* blocked at the ALB with a fixed 403

Only the ALB takes traffic from the internet. The web servers only take traffic from the ALB, and the database only takes traffic from the web servers. The WAF managed rules cover many common attacks, including several from the OWASP Top 10, but they are not full protection on their own.

9. High Availability and Scalability

Availability

- The ALB has nodes in both public subnets and sends traffic only to targets that pass the /health check.
- The Auto Scaling group spreads its instances over two private app subnets in different AZs.
- RDS Multi-AZ keeps a synchronous standby in the second AZ and fails over on its own. The standby cannot be read from.
- Each AZ has its own NAT Gateway.

Scalability

Policy	Type	Setting
CPU	Target tracking	Average CPU utilisation of 50 percent
Requests	Target tracking	500 ALB requests per target
Step	Step scaling	Scale-out only

- The group runs between 2 and 6 instances.
- RDS storage can grow on its own from 20 GB to 100 GB.
- CloudFront answers cacheable static requests so the web servers do less work.
- When the launch template changes, a rolling instance refresh replaces the instances.

What happens when something fails

Event	Expected behaviour	What is still at risk
One web instance fails	The ALB stops sending traffic to it and the Auto Scaling group can replace it	Replacement depends on the group health check type
One AZ fails	Instances and ALB nodes in the other AZ keep serving; RDS fails over to the standby	Only one instance is left until replacements start; short database interruption
RDS primary fails	RDS promotes the standby automatically	Connections drop during the failover
One NAT Gateway fails	The other AZ keeps its outbound access	Instances in the affected AZ lose outbound access
Traffic spike	Target tracking adds instances up to 6; CloudFront takes the static requests	Scale-out takes time, so requests above capacity may be slow
Region failure	Not handled	The design covers a single Region

10. Monitoring and Reliability

Five CloudWatch alarms send email through an SNS topic when something goes wrong:

1. Auto Scaling group CPU
2. ALB HTTP 5xx errors
3. Unhealthy host count
4. RDS CPU
5. RDS free storage

A CloudWatch dashboard with four widgets shows the main metrics in one place. The instance role also includes CloudWatchAgentServerPolicy, so the CloudWatch agent can send extra metrics and logs. For troubleshooting, Session Manager gives shell access without opening any inbound port.

11. Cost Considerations

There are no dollar amounts in this report because current AWS prices could not be checked. These are the items that cost the most or grow with usage:

Component	Quantity	Cost driver
NAT Gateway	2	Hourly charge plus data processing; runs all the time
EC2	2 to 6	Instance-hours and EBS storage; at least 2 always running
Application Load Balancer	1	Hourly charge plus usage-based capacity
RDS Multi-AZ	1 primary and 1 standby	Instance-hours, storage and backups; costs more than Single-AZ
AWS WAF	1 web ACL	Per web ACL, per rule and per request
CloudFront	1 distribution	Data transfer and requests; price class 100
Other	-	Elastic IPs, CloudWatch, Secrets Manager, SNS, data transfer

To get a real estimate, enter the quantities above into the AWS Pricing Calculator for US East (N. Virginia).

12. Design Limitations

- The ALB can be reached directly, because alb-sg allows 0.0.0.0/0, so users can go around CloudFront. WAF still applies at the ALB.
- CloudFront talks to the ALB over HTTP. There is no ACM certificate or custom domain, so HTTPS does not cover the whole path.
- Route 53 is optional and not turned on. If it is turned on, the alias points to the ALB and not to CloudFront.
- There are no VPC endpoints, so AWS service traffic goes through the NAT Gateways.
- The design covers one Region and has no cross-Region disaster recovery.
- The step scaling policy only scales out. Scaling in is left to target tracking.
- With a minimum of two instances, losing one AZ leaves a single instance until scale-out finishes.
- The RDS standby cannot be read from, so it adds availability but not read capacity.
- RDS deletion protection, a final snapshot and 7-day backup retention are not part of the baseline.

- The application does not read Secrets Manager at runtime. Only the RDS-managed master password is shown.
- Audit logging such as VPC Flow Logs, CloudTrail and ALB or WAF logs is not part of the baseline.
- Only five alarms exist, so other failures such as NAT Gateway problems are not alarmed.
- The design has not been validated in a live AWS account.

13. Future Improvements

1. Limit the ALB to CloudFront traffic using the CloudFront managed prefix list and a secret origin header, with a default action of 403.
2. Use HTTPS from end to end with ACM certificates and a Route 53 custom domain.
3. Turn on RDS deletion protection, a final snapshot and 7-day backup retention.
4. Add VPC Flow Logs, CloudTrail, ALB access logs and WAF logs.
5. Add VPC endpoints and KMS customer managed keys.
6. Have the application read database credentials from Secrets Manager, run the CloudWatch agent and use a pre-built AMI.
7. Separate the development and production environments.
8. Add cross-Region disaster recovery, and read replicas if read capacity is needed.

References

- Amazon VPC: https://docs.aws.amazon.com/vpc/latest/userguide/what-is-amazon-vpc.html
- Application Load Balancer: https://docs.aws.amazon.com/elasticloadbalancing/latest/application/introduction.html
- Amazon EC2 Auto Scaling: https://docs.aws.amazon.com/autoscaling/ec2/userguide/what-is-amazon-ec2-auto-scaling.html
- Amazon RDS Multi-AZ: https://docs.aws.amazon.com/AmazonRDS/latest/UserGuide/Concepts.MultiAZ.html
- Amazon CloudFront: https://docs.aws.amazon.com/AmazonCloudFront/latest/DeveloperGuide/Introduction.html
- AWS WAF: https://docs.aws.amazon.com/waf/latest/developerguide/what-is-aws-waf.html
- Session Manager: https://docs.aws.amazon.com/systems-manager/latest/userguide/session-manager.html
- Amazon CloudWatch: https://docs.aws.amazon.com/AmazonCloudWatch/latest/monitoring/WhatIsCloudWatch.html
- AWS Well-Architected Framework: https://docs.aws.amazon.com/wellarchitected/latest/framework/welcome.html